CAHIER DES CHARGES

Reconnaissance réseau et exploitation de vulnérabilités avec Metasploit

Travaux Pratiques — Formation Bachelor Cybersécurité (NEXA)

ENVIRONNEMENT
Lab isolé, accès via VPN WireGuard, réseau cible 172.20.0.0/24

AUTEUR
Yaël André NEYPATRAIKY

01 CONTEXTE

Dans le cadre de la formation en cybersécurité, ce projet vise à reproduire la démarche d'un test d'intrusion (pentest) de bout en bout, depuis la phase de reconnaissance réseau jusqu'à la validation finale de l'accès obtenu, sur un environnement de laboratoire isolé et dédié à l'apprentissage. L'objectif pédagogique est de comprendre le cycle complet d'un audit offensif tel qu'il serait mené dans un contexte professionnel encadré (mandat, périmètre défini, environnement contrôlé).

02 OBJECTIFS

- Identifier les hôtes actifs et les services exposés sur un périmètre réseau donné.
- Qualifier les versions de services détectées et les rattacher à des vulnérabilités connues et documentées (CVE).
- Mettre en œuvre une démarche d'exploitation structurée à l'aide d'un framework reconnu (Metasploit), dans le respect strict du périmètre autorisé.
- Documenter chaque étape de la démarche, les choix effectués et les résultats obtenus, à des fins de restitution et de traçabilité.
- Valider l'accès obtenu par la récupération d'un élément de preuve (flag) sur chaque cible du lab.

03 PÉRIMÈTRE ET CONTRAINTES

Le projet se limite strictement à l'environnement de laboratoire fourni par l'établissement, accessible uniquement via une connexion VPN dédiée et un fichier de configuration nominatif. Aucune action n'est menée en dehors de ce périmètre. Les cibles sont des machines volontairement vulnérables, mises à disposition à des fins pédagogiques, et ne représentent pas des systèmes de production.

04 MÉTHODOLOGIE GÉNÉRALE

1. Reconnaissance → 2. Qualification → 3. Exploitation → 4. Validation

La démarche suit les grandes phases classiques d'un audit offensif : une phase de reconnaissance (identification des hôtes, des ports et des services exposés), une phase de qualification des vulnérabilités (recoupement des versions détectées avec des bases de référence publiques), une phase d'exploitation encadrée (sélection et configuration d'un module adapté), puis une phase de validation (confirmation de l'accès obtenu et récupération d'une preuve). Pour des raisons de sécurité et de confidentialité méthodologique, le détail technique des commandes, des modules et des paramètres d'exploitation n'est pas communiqué dans ce document de synthèse.

05 DIFFICULTÉS RENCONTRÉES

- Correspondance imparfaite entre les résultats d'une recherche de module incluant le numéro de version exact et les modules réellement disponibles, nécessitant d'élargir la recherche pour trouver une option exploitable.
- Écart entre le port attendu pour l'exécution d'une charge utile (payload) et le port réellement ouvert sur la machine cible, imposant une reconnaissance complémentaire pour identifier l'ensemble des ports exposés avant de relancer l'exploitation.
- Identification du type de hash récupéré lors de l'extraction des informations d'authentification, nécessitant un outil dédié avant de pouvoir engager une tentative de cassage adaptée.

06 LIVRABLES

- Une documentation structurée de chaque étape de la démarche (reconnaissance, qualification, exploitation, validation).
- Une synthèse des difficultés rencontrées et des ajustements méthodologiques apportés.
- La confirmation de l'accès obtenu sur chacune des cibles du périmètre, par la récupération d'un élément de preuve dédié.